

Controlled proof and selective fix verification

Assessment

Title

Controlled proof and selective fix verification

Assessment ID

reproducible-local-assessment

Reviewer

AuthzLedger synthetic fixture

Period

Retained execution timestamps

Snapshot

3986f521b14a21ba7785c92d6b0d20afd70581b68f1e29e6cce2a29441c72167

Renderer

assessment-html-pdf-v1-reportlab-4.4.9-dejavu-2.37

Executive summary

Summary

Evidence-backed assessment of explicitly selected security rules.

Finding status

```
{"candidate": 0, "confirmed": 0, "rejected": 0, "retest_pending": 1, "retest_verified": 1}
```

Scope and methodology

Scope

http://127.0.0.1:44441

Method

Explicit rules, source-bound requests and valid controls. Evidence remains local; observations are reviewed at their recorded verification level.

Coverage

```
[{"comparison_sha256": "c9f2c591b6d6a16c06267eae32e4184a7e53f70e4cc5ea7ffadc2178fd37d389",  
"dependency_cases": 3, "not_retested_cases": 1, "retested_cases": 4, "selected_cases": 1, "source_cases": 5}]
```

Tenant B must not receive Tenant A invoice content

Finding ID

finding-c05b584f5c488a0155a3397e

Status

retest_pending

Execution record status

confirmed

Interpretation

violation

Category

denial_data_disclosure

Rule digest

b998c742eb0fa660c51a813c5b9a5aecf3385cdd950a870bbb839b48036eb11f

Resource

invoice-a

Identity

peer

Case

variant-peer-2

Reproduction

GET /invoices/a as peer; execute controls before this case. Use the retained source contract and environment/session credential references.

Expected checks

```
{"json_absent": ["/protected_marker"], "status": [401, 403, 404]}
```

Observation

```
{ "body_complete": true, "controls_valid": true, "interpretation": "violation", "status": 403, "verification_level": "captured_inputs_replayed" }
```

Controls

actor-identity-0, known-denial-0, owner-object

Evidence

4ca7d7419ef4c8166b8a174a42892e6138c6674ee3e75d11c71b999346803695

Source report root

e898f401667d0efa524647c5c6825c3c21e8dd2b598b132f0370faf441115265

Finding record digest

55721a82bf7429f2adec50a351be6d18ab8c47064eb383942c930ec22e413d64

Verification level

captured_inputs_replayed

Impact

The configured protected marker was disclosed to the tested identity.

Remediation

Enforce the configured rule at the resource and response boundary; rerun this experiment with fresh controls.

Business risk

Not assessed by reviewer

CVSS 4.0

not_scored; vector: not supplied

Retest

```
[{"baseline_root": "e898f401667d0efa524647c5c6825c3c21e8dd2b598b132f0370faf441115265",  
"case_id": "variant-peer-2", "comparison_digest":  
"8948216dbab3f1ea0ff1279cad0c18f919e875c29d007d7e4e3a07bcab9fa7c3", "comparison_sha256":  
"c9f2c591b6d6a16c06267eae32e4184a7e53f70e4cc5ea7ffadc2178fd37d389", "current_root":  
"1f0f673f4eb5a13b4a3a859c89d8145b7dbef28a2aaf47e316403e61598d9830", "finding_status":  
"not_retested", "status": "not_retested"}]
```

Standards mapping

No requirement-level mapping reviewed.

Limitations

Remote response authenticity is not established by local signing.

Only selected oracle inputs are replayed; their projection from the omitted raw body remains signer-attested.

Tenant B must not receive Tenant A invoice content

Finding ID

finding-cabbe355c68937e2311bb886

Status

retest_verified

Execution record status

rejected

Interpretation

satisfied

Category

authorization_rule_violation

Rule digest

b998c742eb0fa660c51a813c5b9a5aecf3385cdd950a870bbb839b48036eb11f

Resource

invoice-a

Identity

peer

Case

variant-peer-1

Reproduction

GET /invoices/a as peer; execute controls before this case. Use the retained source contract and environment/session credential references.

Expected checks

```
{"json_absent": ["/protected_marker"], "status": [401, 403, 404]}
```

Observation

```
[{"body_complete": true, "controls_valid": true, "interpretation": "satisfied", "status": 403, "verification_level": "captured_inputs_replayed"}]
```

Controls

actor-identity-0, known-denial-0, owner-object

Evidence

40f61d1218941f67ad31e7d0dd8db436449a1bf76cc7750f254e9b56613c0f01

Source report root

1f0f673f4eb5a13b4a3a859c89d8145b7dbef28a2aaf47e316403e61598d9830

Finding record digest

2ec8af089563ffb091cd01649172ea939d17cdd480b03d620705e3f276ec0651

Verification level

captured_inputs_replayed

Impact

Limited to the explicitly evaluated predicate; business impact requires review.

Remediation

Enforce the configured rule at the resource and response boundary; rerun this experiment with fresh controls.

Business risk

Not assessed by reviewer

CVSS 4.0

not_scored; vector: not supplied

Retest

```
[{"baseline_root": "e898f401667d0efa524647c5c6825c3c21e8dd2b598b132f0370faf441115265", "case_id": "variant-peer-1", "comparison_digest": "8948216dbab3f1ea0ff1279cad0c18f919e875c29d007d7e4e3a07bcab9fa7c3", "comparison_sha256": "c9f2c591b6d6a16c06267eae32e4184a7e53f70e4cc5ea7ffadc2178fd37d389", "current_root": "1f0f673f4eb5a13b4a3a859c89d8145b7dbef28a2aaf47e316403e61598d9830", "finding_status": "fix_verified", "status": "resolved_check"}]
```

Standards mapping

No requirement-level mapping reviewed.

Limitations

Remote response authenticity is not established by local signing.

Only selected oracle inputs are replayed; their projection from the omitted raw body remains signer-attested.

Standards profile

API 2023

<https://api-security.owasp.org/editions/2023/en/0x11-t10/>

ASVS 5.0.0

<https://github.com/OWASP/ASVS/tree/v5.0.0>

CVSS 4.0

<https://www.first.org/cvss/v4.0/specification-document>

WSTG 4.2

<https://wstg.owasp.org/v4.2/>

Limitations and independent verification

Limitation

This is a scoped assessment, not certification or complete ASVS/WSTG/API coverage.

Limitation

Finding status, technical severity and business risk are separate dimensions.

Limitation

A restored configured check is not automatically a verified vulnerability fix.

Limitation

Retest omissions retain not_retested and historical evidence only.

Limitation

Signatures authenticate retained bytes and signing keys; they do not prove remote execution truth.

Limitation

Replayed oracle inputs are approved projections; their relationship to unavailable raw response bytes remains signer-attested.

Limitation

The standalone verifier provides integrity_only; semantic verification requires AuthzLedger and the pinned report renderer.

Limitation

Authored synthetic import fixture; this run is not a third-party exporter certification.

Limitation

A selected fix proves only the retained rule, identity, object and configured controls.

Verify

Obtain the public-key fingerprint through an independent trusted channel. Run: `python3 -I verify_bundle.py PACKAGE --public-key TRUSTED.pem`. The package manifest supplies the signer fingerprint. Then run AuthzLedger verify-bundle for retained evidence and exact report semantics. Never trust a key solely because it is inside the package.